

EXERCISE AND HOMEWORK SHEET



CERTIFIED ISO/IEC 27001 LEAD
IMPLEMENTER TRAINING COURSE

Exercise 1: Reasons to implement an ISMS based on ISO/IEC 27001

Read the section “Recent Events” in the case study and list the main benefits that *e-Scooter* can gain by implementing an information security management system (ISMS) based on ISO/IEC 27001.

[illegible]

Homework 1: Classification of controls

For each of the following information security controls, determine their function (preventive, corrective, or detective) and their type (administrative, technical, managerial, or legal).

Example: Provision of awareness and training related to information security to employees within the organization

By function, this is a preventive control that aims to reduce the likelihood of security incidents and ensure that employees understand security risks and security practices. By type, it is an administrative control.

1. Segregation of information security roles and responsibilities within the organization

.....

.....

.....

.....

.....

.....

2. The implementation of the screening process for potential candidates prior to joining the organization

.....

.....

.....

.....

.....

.....

3. Logging of user activities

.....

.....

.....

.....

.....

.....

4. Investigation of security incidents

.....

.....

.....

.....

.....

.....

5. Consideration of applicable legislation

.....

.....

.....

.....

.....

.....

Homework 2: Establishing the ISMS context

Based on the case study, *e-Scooter* decided to implement an ISMS based on ISO/IEC 27001 after a few security incidents occurred. As a member of the ISMS project team, you are assigned to identify the compliance requirements that *e-Scooter* must fulfill and to identify some of its critical information assets and business processes. List at least two elements for each of these.

Compliance requirement 1:
.....
.....
.....

Compliance requirement 2:
.....
.....
.....

Information asset 1:
.....
.....
.....

Information asset 2:
.....
.....
.....

Information asset 3:
.....
.....
.....

Business process 1:

.....

.....

.....

Business process 2:

.....

.....

.....

.....

Business process 3:

.....

.....

.....

Homework 3: Definition of the scope

Based on the case study, establish the scope for *e-Scooter*'s ISMS and determine its boundaries. The management wishes that the scope will be perceived as having an added value to its customers and, at the same time, delimit it as much as possible for the initial certification of the ISMS.

Scope:

.....

.....

.....

.....

Explanation and justification:

.....

.....

.....

.....

Define the organizational boundaries:

.....

.....

.....

.....

Define the boundaries of information systems:

.....

.....

.....

.....

Define the physical boundaries:

.....

.....

.....

.....

.....

Exercise 2: Identification of threats and vulnerabilities

Determine the threats and vulnerabilities associated with the following scenarios. In addition, indicate if the consequences would affect the confidentiality, integrity, or availability of the organization's information.

1. Internal audit results indicated that the user credentials of a former employee were still being used.
2. An employee made a wrong input value into the command line interface of the development server which shut down the entire server.
3. The beta version of the application was lost when an array of hard disks installed in developer machines were proven to be faulty and failed.

Complete the risk matrix and prepare to discuss your answers.

Risk scenarios	Threat	Vulnerability	Consequences	C	I	A
1. Internal audit results indicated that the user credentials of a former employee were still being used.						
2. An employee made a wrong input value into the command line interface of the development server which shut down the entire server.						
3. The beta version of the application was lost when an array of hard disks installed in developer machines were proven to be faulty and failed.						

By referring to the case study, rate the maturity level of the process of accessing customer data stored in the blockchain. In addition, provide recommendations for the improvement of the process, so that the company fulfills the requirements of control 5.15 *Access control* of ISO/IEC 27001.

This image shows a single sheet of white paper with horizontal ruling lines. The lines are evenly spaced and run across the width of the page. There are no margins, text, or other markings on the paper.

Homework 5: Drafting a security policy

Following a recent information security incident in the company, *e-Scooter* has decided to establish a policy to control the use of all communication devices (e.g., smartphones, tablets, and other forms of portable communication devices) in the workplace.

To draft the smartphone usage policy, complete the provided template below.

SMARTPHONE USAGE POLICY	
Introduction	
Objective	
Scope	
Principles	
Responsibilities	
Key outcomes	
Penalties	
Related policies	

Homework 6: Risk treatment options

After conducting a thorough risk assessment, the project manager identifies a significant information security concern within the company they work. It is revealed that 0.5% of electronic transactions, translating to a turnover of \$10 million, conducted through credit cards on the company's application are susceptible to unauthorized access and potential data breaches. This poses a threat to both the financial aspect of the company and the confidentiality and integrity of customer data. The top management of the company must take an important decision on how to address and mitigate the identified.

Propose four risk treatment options to address the risk and list the activities that should be taken based on these options.

Option 1:

.....

.....

.....

Option 2:

.....

.....

.....

Option 3:

.....

.....

.....

Option 4:

.....

.....

.....

Homework 7: Monitoring and reviewing the risk management process

Based on the case study, explain why it is important for *e-Scooter* to monitor and review its risk management process. List three risks that the company would be facing in case it fails to take such actions.

This image shows a full page of primary-ruled paper. It features multiple horizontal rows, each defined by two parallel dotted lines. The rows are evenly spaced across the entire page, providing a guide for handwriting practice. There are no margins, text, or other markings present.

Exercise 3: Security controls

Provide an action plan which consists of at least two actions that should be taken to ensure conformity to the following clauses and controls of ISO/IEC 27001.

Example: Annex A 8.8 Management of technical vulnerabilities

- *Implement a systematic process for conducting regular vulnerability assessments on the IT infrastructure, applications, and network components.*
- *Develop a robust patch management process to promptly apply security patches and updates to operating systems, applications, and software. This process should include timely testing and deployment of patches to minimize the risk of exploitation by malicious actors.*

1. Clause 7.2 a) The organization shall determine the necessary competence of person(s) doing work under its control that affects its information security performance

.....

.....

.....

.....

2. Clause 10.2 a) When a nonconformity occurs, the organization shall react to the nonconformity

.....

.....

.....

.....

3. Annex A 8.6 Capacity management

.....

.....

.....

.....

4. Annex A 8.7 *Protection against malware*

.....

.....

.....

.....

5. Annex A 5.14 *Information transfer*

.....

.....

.....

.....

Homework 8: Management of documented information

Provide a list of documents (at least three) that should be generated to ensure conformity to the Annex A 5.29.

[illegible]

e-Scooter wants to apply the flexibility to pay both online and in cash. What steps should the company take in order to ensure the security of information when customers want to pay online and enter personal information in order to make payments directly through their bank accounts?

[illegible]

Homework 10: Awareness and training program

Based on the case study, *e-Scooter* provided training and awareness sessions related to information security only for the software development team. This could lead to the inability of other employees within the company to prevent information security breaches and cyberattacks.

Explain the importance of organizing training and awareness programs in a company and propose actions that should be taken in order for the training and awareness programs to be effective.

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Homework 11: Audit findings

An internal audit has been conducted by *e-Scooter*'s internal auditor in order to obtain information on whether the ISMS is being implemented effectively and whether it is conforming

[illegible]

Exercise 4: Development of performance indicators

Provide two indicators that would help in evaluating the performance of an organization with regard to the implementation of the following clause requirements and controls outlined in ISO/IEC 27001.

Example: Clause 5.1 Leadership and commitment

- *The number of management review meetings conducted*
- *The average participation rate in management review meetings*

1. Clause 10.2 Nonconformity and corrective action

.....

.....

2. Annex A 5.3. Organizational roles, responsibilities and authorities

.....

.....

3. Annex A 5.9 Inventory of information and other associated assets

.....

.....

4. Annex A 5.17 Authentication information

.....

.....

Explain the purpose of a management review, elaborating on the critical factors that require thorough consideration during the review. Additionally, provide the key steps needed to prepare for a management review.

This image shows a full page of white paper with horizontal ruling lines. The lines are evenly spaced and extend across the width of the page. There are no margins, text, or other markings on the paper.